

Data Security Fundamentals and Key Regulations

In this lesson, we'll explore the fundamental principles of data security and their importance in safeguarding sensitive information. We'll learn how regulations and standards shape robust security frameworks for modern data engineering.

Learning Objectives

By the end of this lesson, you should be able to:

- Understand why data security is required.
- Be able to describe the security practices for working with big data.
- Understand how a defence-in-depth approach can be used to secure applications.

1. Why is Data Security Increasingly Important?

Data security is a great concern to both **individuals and organisations**, for various reasons. Specifically for organisations, data security is paramount due to the consequences of a **data breach**, which includes reputation damage, loss of customer trust, and the eventual loss of business.



IBM's 2020 *Cost of a Data Breach Report* found that **loss of business is the largest contributing factor to data breaches**, accounting for nearly 40% of the average total cost of a breach.

Because of the increasing role of data in our everyday lives, governments are introducing more rigorous regulations around data privacy. The consequences of data breaches

include **fines and litigations** and, as a result, the costs of rectifying such breaches are also increasing.

It is, thus, paramount for any organisation to have sufficient data security in place to avoid data breaches and ensure no significant **data or monetary loss**.

2. Data Security Principles

Data security as a set of **principles and practices** enables the **protection** of sensitive and critical data, personal identifiable information (PII), and the broader information ecosystem.

There are three main principles in data security: **Confidentiality**, **Integrity**, and **Availability**. This is called the **CIA triad**, which functions as a framework for data security.



The CIA triad of data security.

Confidentiality



Ensures that data access is only enabled for those with the correct authorisation.

Integrity



Ensures that data are protected from unauthorised or erroneous changes.

Availability



Ensures that data are safely and readily available and accessible to those with authorisation.

A compromise of any of these principles can result in serious consequences for the organisation, data engineers, and users.

2.1 Data Security Regulations and Standards

Enforced data regulations and standards include the **General Data Protection Regulation (GDPR)**, **Data Protection Act 2018 (DPA)**, and **Protection of Personal Information Act (POPI Act, or POPIA)**.

General Data Protection Regulation 2016/679 (GDPR):

The GDPR is a European Union (EU) regulation specifically on data protection and privacy. It requires an **appropriate** level of security in response to the level of risk present in the processing and sensitivity of the data.

Although established under EU law, it has become a model for many national data laws, including the **California Consumer Privacy Act (CCPA)** and the **South African Protection of Personal Information Act (POPIA)**.

Protection of Personal Information Act (POPIA):

In 2021, South Africa implemented the **Protection of Personal Information Act (POPIA)**. The main principles include:

POPIA main principles

- Personal data must be obtained fairly and legally.
- Personal data can only be used for the purpose it was specifically obtained for.
- Whoever processes the data is responsible for ensuring the quality thereof.
- Whoever processes the data should be transparent and honest about processing personal data.
- Whoever processes the data should ensure proper data security measures are in place.

POPIA exceptions

- If it's purely for personal or household use.
- If it involves national security, or if it's used to prevent or detect illegal activity.
- If it's used by the South African Cabinet, its committees, or provincial executive councils.
- If it's used for the court's judicial functions.
- If it's used for literary, journalistic, or artistic purposes.

ISO/IEC 27001:

The **ISO/IEC 27001** is a widely known **Information Security Management System (ISMS) standard**. Although not obligatory, accreditation reassures stakeholders that international security recommendations have been followed.

ISO/IEC 27001 standard requirements

- Systemic assessment of an organisation's information security risks.
- The design and implementation of a comprehensive set of security controls.
- The implementation of a general security management process.

ISO/IEC 27701:

The **ISO/IEC 27701** standard is a certifiable **extension of 27001** that centres around improving the privacy of information security management systems.

Conclusion

Effective data security is crucial for protecting both **personal and organisational** information. By adhering to the CIA triad and following relevant regulations such as GDPR and POPIA, organisations can ensure a robust security framework.

Key Takeaways



- **Takeaway 1:** Data security is essential to prevent financial loss, reputational damage, and legal consequences caused by breaches.
- **Takeaway 2:** The CIA triad (Confidentiality, Integrity, and Availability) forms the core framework for protecting sensitive and critical information.
- **Takeaway 3:** GDPR requires organisations to implement security measures appropriate to the sensitivity and risk level of data.
- **Takeaway 4:** POPIA outlines administrative principles for protecting personal data in South Africa.
- **Takeaway 5:** ISO/IEC 27001 and ISO/IEC 27701 are voluntary but internationally recognised standards that demonstrate strong information security and privacy practices.